ORION-RECON

Orion Cloud Network Portal — Reconocimiento y descubrimiento de servicios

Objetivo	ORION-RECON (Cisco Session 1) · `172.17.0.2`
Plataforma	whoami-labs.com — laboratorio aislado y autorizado
Tipo de prueba	Caja negra (black-box), sin credenciales previas
Dificultad	Fácil (1 punto) ★☆☆☆☆☆☆☆
Fecha de ejecución	2026-11-04 a 2026-11-06
Duración del laboratorio	00h 02m 13s
Autor	Josep Sanz
Flag obtenida	`CISCO_ORION{0r10n_s3rv1c3_d1sc0v3ry_m4st3r}`

Aviso de alcance y legalidad. Todas las pruebas descritas en este documento se han realizado exclusivamente contra una máquina de laboratorio desplegada en la plataforma **whoami-labs.com**, que autoriza explícitamente la actividad ofensiva sobre sus retos. No se ha atacado ningún sistema de terceros. La dirección `172.17.0.2` corresponde al contenedor del reto dentro de la red Docker del propio laboratorio.

1. Resumen ejecutivo

Se ha realizado una prueba de intrusión de tipo caja negra contra la máquina **ORION-RECON**, un portal que simula un nodo de gestión de red «Orion Cloud Network Portal». El objetivo del reto es de nivel **reconocimiento**: localizar la *flag* de verificación aplicando descubrimiento de servicios y enumeración web, sin necesidad de explotar vulnerabilidades complejas.

Mediante escaneo de puertos con Nmap y enumeración de directorios con Feroxbuster se identificó un fichero de notas internas de mantenimiento (`/dev_notes.txt`) expuesto públicamente en el servidor web. Dicho fichero contenía la *flag* del reto junto con información sensible de configuración (versiones de software, existencia de un directorio sin índice público y una API de diagnóstico interna). El hallazgo demuestra el riesgo principal de la fase de reconocimiento: **la exposición involuntaria de información sensible por mala configuración**.

#	Hallazgo	Severidad	CWE
H-01	Exposición de información sensible en fichero de notas internas (`/dev_notes.txt`)	Alta	CWE-200 / CWE-538
H-02	Listado de directorios habilitado (`/uploads/`)	Media	CWE-548
H-03	Fuga de versiones de software en banners y cabeceras	Baja	CWE-200
H-04	API de diagnóstico interna accesible sin autenticación (puerto 8080)	Media	CWE-306

2. Alcance y metodología

La prueba se ha limitado a un único host (`172.17.0.2`) y se ha abordado siguiendo las fases estándar de un ejercicio de intrusión, mapeadas al marco **MITRE ATT&CK**:

- **Reconocimiento (TA0043):** descubrimiento de host, puertos y servicios — *Active Scanning (T1595)*.
- **Descubrimiento (TA0007):** enumeración de contenido web y recursos — *T1083, T1046*.
- **Recolección (TA0009):** obtención de la información expuesta y la flag.

Herramientas empleadas: `nmap` , `feroxbuster` y navegador web (Firefox sobre Kali Linux).



Figura 1 — Despliegue del laboratorio ORION-RECON en whoami-labs.com. Se asigna la IP objetivo 172.17.0.2 y se indica el formato de la flag (`CISCO_ORION{ ... }`).

3. Desarrollo técnico

3.1 Descubrimiento de puertos y servicios (Nmap)

Se lanzó un escaneo completo de los 65.535 puertos TCP con detección de versión y scripts por defecto:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló tres servicios abiertos:

Puerto	Servicio	Versión / Detalle
22/tcp	SSH	OpenSSH 9.2p1 Debian (protocolo 2.0)
80/tcp	HTTP	Apache httpd 2.4.68 (Debian) — «Orion Cloud Network Portal». `robots.txt` con 3 entradas: `/dev_notes.txt`, `/uploads/`, `/internal/`
8080/tcp	HTTP	SimpleHTTPServer 0.6 (Python 3.11.2) — respuesta tipo `application/json` (API)

El dato más relevante del escaneo es que el script `http-robots.txt` de Nmap ya revela **tres rutas «no permitidas»** en el `robots.txt` del servidor. Lejos de protegerlas, esto actúa como un mapa directo de los recursos sensibles: `/dev_notes.txt`, `/uploads/` e `/internal/`.

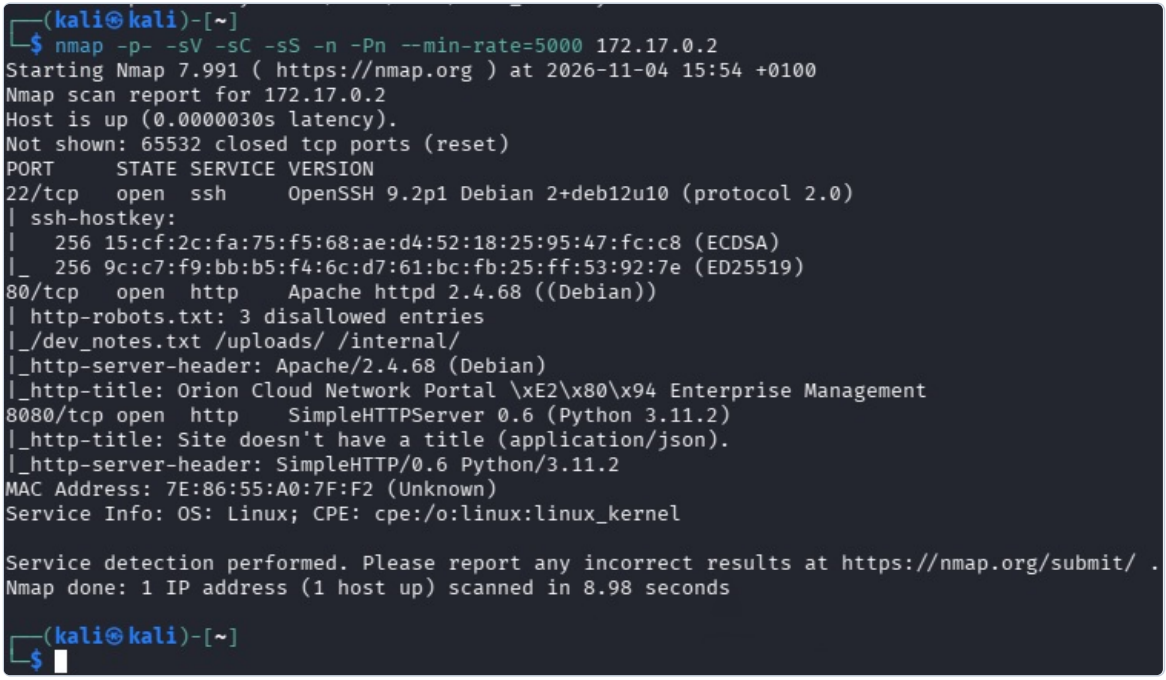


Figura 2 — Salida de Nmap: puertos 22 (SSH), 80 (Apache) y 8080 (API Python). Nótese la fuga de las 3 rutas de `robots.txt` y las versiones exactas de los servicios.

3.2 Enumeración web del puerto 80 (Feroxbuster)

Se enumeró el contenido del servidor Apache con Feroxbuster y una lista de directorios de tamaño medio:

```
feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Resultados destacados:

Código	Recurso	Observación
200	`/dev_notes.txt`	Fichero de notas internas (12 líneas) — **contiene la flag**
301 → listing	`/uploads/`	Directorio con **listado público habilitado** (Directory listing)
301 / 200	`/internal/` , `/internal/index.html`	Sección «interna» accesible sin autenticación
200	`/login.php`	Formulario de acceso
200	`/robots.txt`	Confirma las rutas sensibles



Figura 3 — Enumeración del puerto 80. Feroxbuster confirma `/dev_notes.txt`, un `/uploads/` con Directory listing activo, `/internal/` y `/login.php`.

3.3 Enumeración de la API del puerto 8080 (Feroxbuster)

Se repitió la enumeración contra el servicio Python del puerto 8080:

```
feroxbuster -u http://172.17.0.2:8080 -t 5 -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Se identificaron dos endpoints de la API de diagnóstico interna, accesibles sin ningún tipo de autenticación:

Código	Endpoint	Observación
200	`/status`	Estado del servicio (JSON)
200	`/metrics`	Métricas internas del nodo (JSON)

Esta es la «API de diagnóstico interno» mencionada explícitamente en las notas de mantenimiento, lo que confirma que un recurso pensado para uso interno queda expuesto a cualquier cliente de la red.

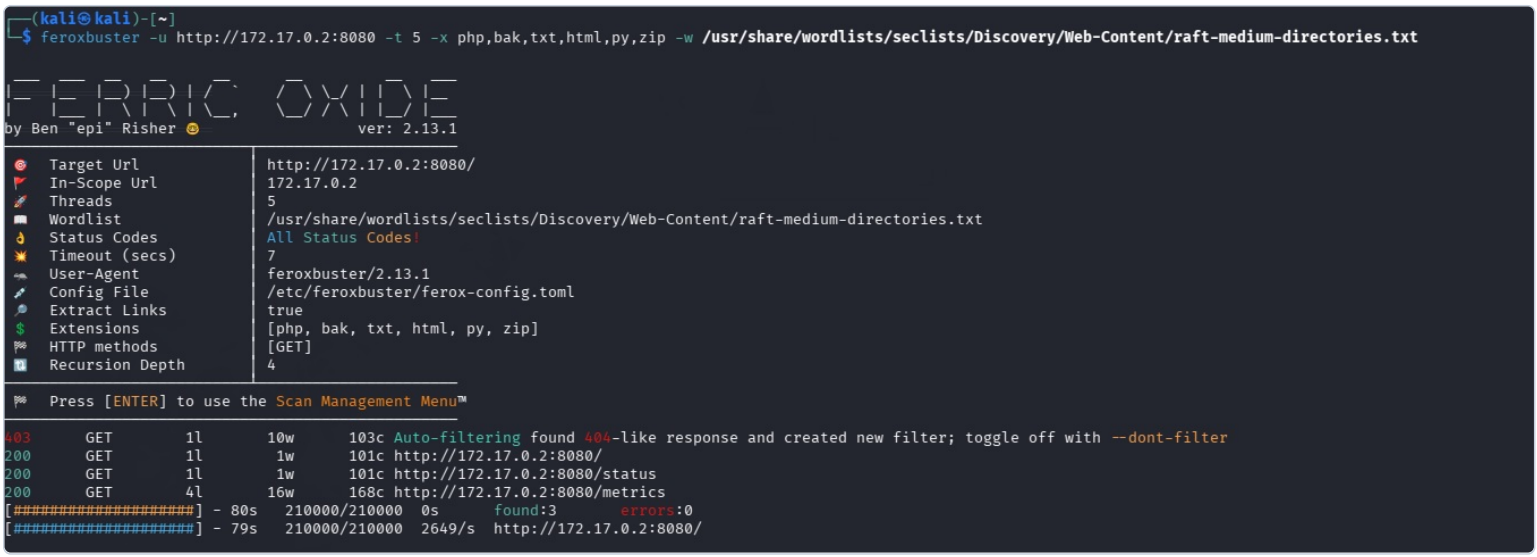


Figura 4 — Enumeración del puerto 8080. Los endpoints `/status` y `/metrics` de la API de diagnóstico responden sin autenticación.

3.4 Obtención de la flag (/dev_notes.txt)

Al acceder directamente a `http://172.17.0.2/dev_notes.txt` desde el navegador se obtuvo un fichero de «Notas internas de mantenimiento» del nodo Orion Cloud. Además de la flag, el documento filtra información operativa de valor para un atacante:

- Que el servicio SSH del puerto 22 se actualizó a OpenSSH 9.2p1 (confirma versión).

- Un recordatorio a «auditores externos» de que el directorio `/uploads/` «no tiene listado público» — afirmación que la Figura 3 desmiente.
- Que se ha habilitado la API de diagnóstico interno en el puerto 8080.
- La propia **flag de verificación de reconocimiento**.

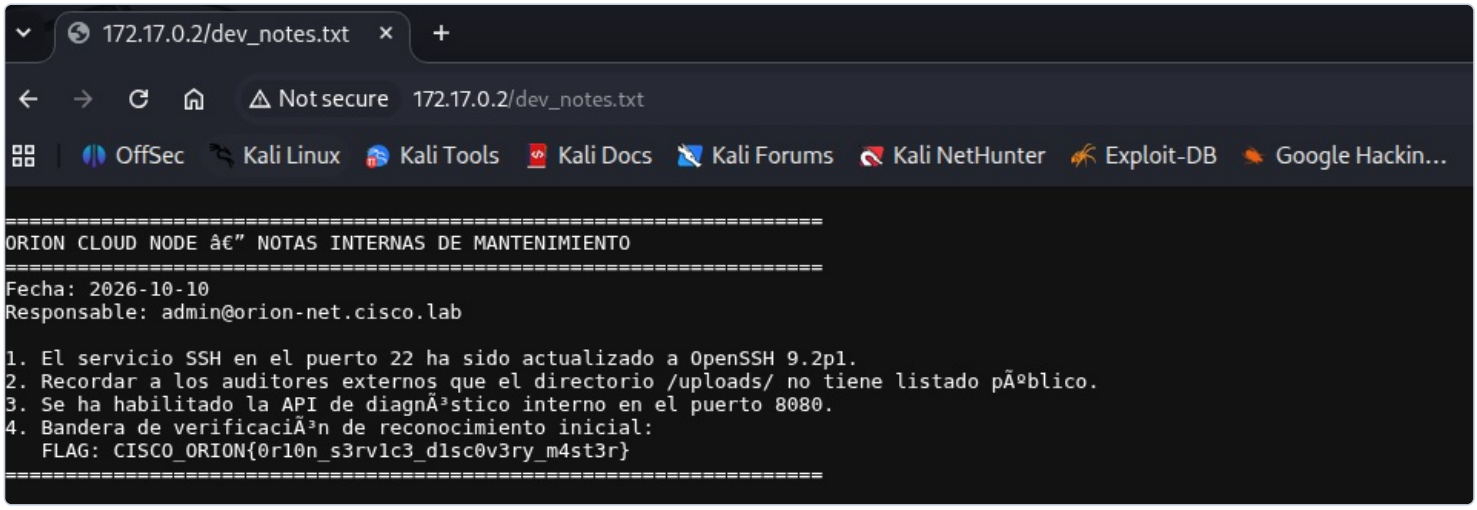


Figura 5 — Contenido de `/dev_notes.txt`: notas internas de mantenimiento que exponen versiones, rutas y la flag del reto.

Flag obtenida:

```
CISCO_ORION{0r10n_s3rv1c3_d1sc0v3ry_m4st3r}
```

4. Hallazgos detallados

H-01 · Exposición de información sensible en notas internas Alta

Descripción. El fichero `/dev_notes.txt`, accesible públicamente sin autenticación, contiene notas de mantenimiento con versiones de software, rutas internas, descripción de una API de diagnóstico y la flag del reto. Equivale a la filtración de documentación operativa interna.

Clasificación. CWE-200 (Exposure of Sensitive Information) / CWE-538 (File and Directory Information Exposure) · OWASP **A01:2021 – Broken Access Control** y **A05:2021 – Security Misconfiguration**.

CVSS 3.1. 7.5 (Alta) — `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`.

Impacto. Un atacante obtiene un mapa de la infraestructura (versiones exactas para buscar exploits, ubicación de recursos ocultos y existencia de servicios internos) que reduce drásticamente el esfuerzo de las fases posteriores del ataque.

H-02 · Listado de directorios habilitado en /uploads/ Media

Descripción. El directorio `/uploads/` devuelve un índice navegable de su contenido (*Directory listing*), en contradicción directa con lo afirmado en las notas internas.

Clasificación. CWE-548 (Exposure of Information Through Directory Listing) · OWASP A05:2021.

CVSS 3.1. 5.3 (Media) — `AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`.

Impacto. Permite descubrir y descargar ficheros que no deberían ser públicos sin conocer su nombre previamente.

H-04 · API de diagnóstico sin autenticación (8080) Media

Descripción. El servicio Python del puerto 8080 expone los endpoints `/status` y `/metrics` sin ningún control de acceso. Un `SimpleHTTPServer` de desarrollo opera como si fuera un servicio interno.

Clasificación. CWE-306 (Missing Authentication for Critical Function) · OWASP A01:2021 / A05:2021.

CVSS 3.1. 5.3 (Media) — `AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`.

Impacto. Divulgación de métricas y estado interno del nodo; superficie de ataque adicional si la API crece en funcionalidad.

H-03 · Fuga de versiones de software Baja

Descripción. Los banners de servicio y las cabeceras HTTP revelan versiones exactas: OpenSSH 9.2p1, Apache 2.4.68, Python 3.11.2. El `robots.txt` además enumera rutas sensibles.

Clasificación. CWE-200 · OWASP A05:2021.

CVSS 3.1. 3.7 (Baja) — `AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N`.

Impacto. Facilita la correlación con vulnerabilidades públicas conocidas (CVE) para cada versión.

5. Recomendaciones de remediación

1. **Retirar los ficheros de notas del servidor web.** Ningún documento interno (notas, credenciales, versiones) debe residir en la raíz web. Mover la documentación a un repositorio interno con control de acceso.
2. **Deshabilitar el listado de directorios** en Apache (`Options -Indexes`) y aplicar una denegación por defecto sobre `/uploads/` e `/internal/`.
3. **No confiar en `robots.txt` como control de seguridad.** No es un mecanismo de protección; elimina de él cualquier ruta sensible y protégela con autenticación real.
4. **Autenticar la API de diagnóstico** del puerto 8080 y restringirla por red (bind a `127.0.0.1` o firewall). Sustituir el `SimpleHTTPServer` de desarrollo por un servidor de producción.
5. **Ocultar banners y versiones** (`ServerTokens Prod` , `ServerSignature Off` en Apache) como defensa en profundidad.
6. **Revisión de configuración previa a producción:** incorporar un checklist de *hardening* (CIS Benchmarks) que detecte estas malas configuraciones antes del despliegue.

6. Conclusión y lección aprendida

ORION-RECON ilustra que la fase de **reconocimiento**, por sí sola, puede comprometer a una organización sin necesidad de explotar una sola vulnerabilidad de código. El compromiso no vino de un fallo técnico sofisticado, sino de una **mala configuración**: documentación interna publicada en la raíz web, un `robots.txt` que actúa de índice de lo sensible y servicios de desarrollo expuestos en producción.

La lección es doble. Primero, **la información es un activo**: versiones, rutas y la existencia de servicios internos tienen valor para un atacante aunque no sean «la flag». Segundo, **ocultar no es proteger**: confiar en que un directorio «no tiene listado público» o en que `robots.txt` mantendrá algo en secreto es equivalente a no tener ningún control. La protección real exige autenticación, denegación por defecto y una revisión de *hardening* antes de exponer cualquier servicio.

Documento generado como registro de la máquina ORION-RECON (whoami-labs.com) · 2026-11-06 · Prueba realizada en entorno de laboratorio autorizado. Las 5 figuras incluidas constituyen la evidencia de la prueba.